T1 JATETXEA: DISEINUA, BALIDAZIOAK ETA TRANSAKZIOAK

Zerbitzariaren Komanden Kudeaketa Aplikazioa (Tableta)

Erronka entrega datuak:	
Modulua	Zibersegurtasuna – 1. Ebaluazioa (Erronka entrega)
Arkitektura	Frontend (Tablet UX) + Backend (C# REST API) + MySQL 8.4 InnoDB
Egileak	Juler, Iker, Ander U.

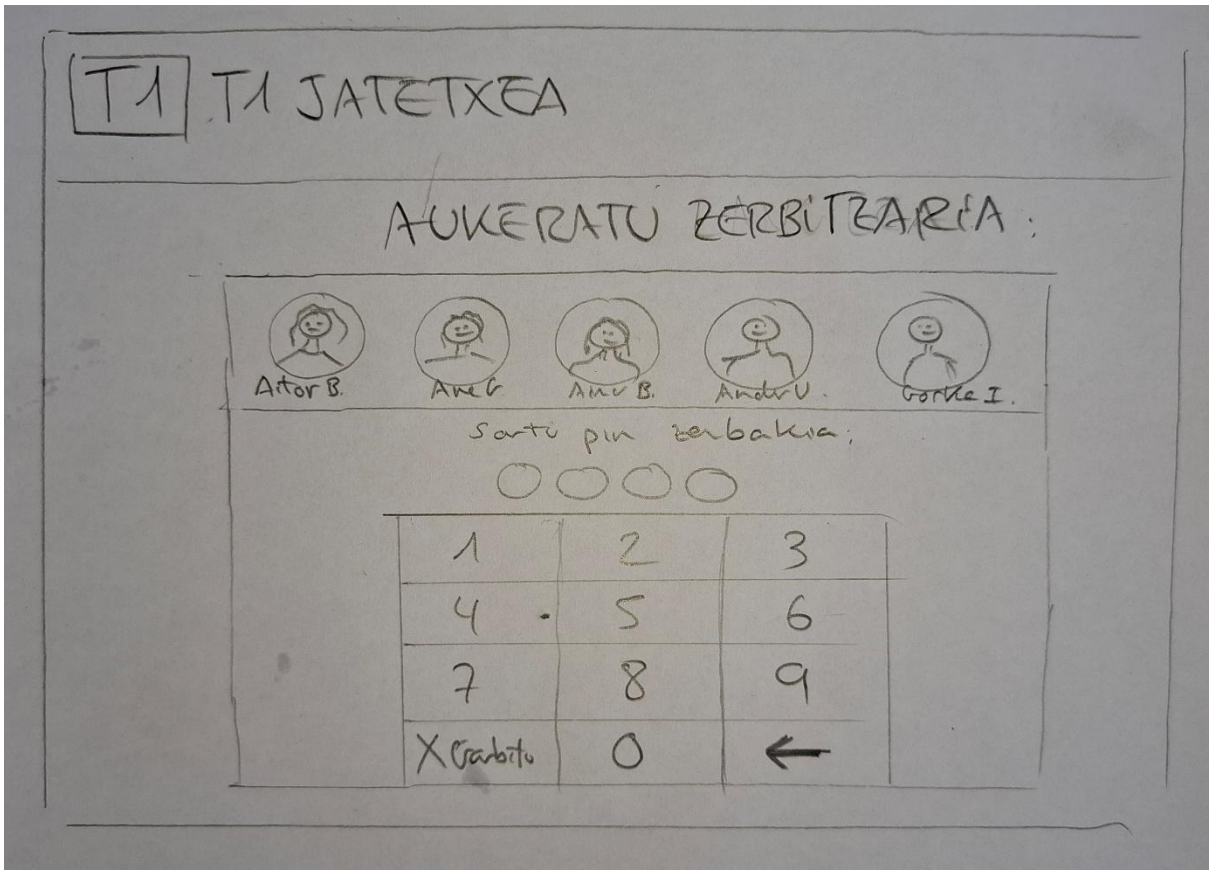
Edukia

1. Interfaze diseinuak 2
1.1 Pantaila: Saioa Hasi (Login) 2
1.2 Pantaila: Mahaien Zerrenda eta Mapa 3
1.3 Pantaila: Mahaikide Kopuruaren Hautatzailea (Modala / Pop-up) 4
1.4 Pantaila: Produktuak eta Karritoa (Komanda Sortzea) 5
1.5 Pantaila: X. Mahaiaren Pantaila (Mahaiaren Xehetasuna) 6
2.Front-ean zein balidazioak 7
2.1 Helburua 7
2.2Frontend Balidazioak 7
3. Back-ean balidazioak 8
3.1 Egingo diren Balidazio Nagusiak eta Nola 8
4. Transakziok eta nola aplikatu 9
4.1 Arazo posibleak eta nola saihestu transakzioekin 9

1. Interfaze diseinuak

1.1 Pantaila: Saioa Hasi (Login)

Zerbitzariaren identifikazio azkarra tablet bidez. Zerbitzaria hautatu eta PIN zenbakizkoa sartzen da.

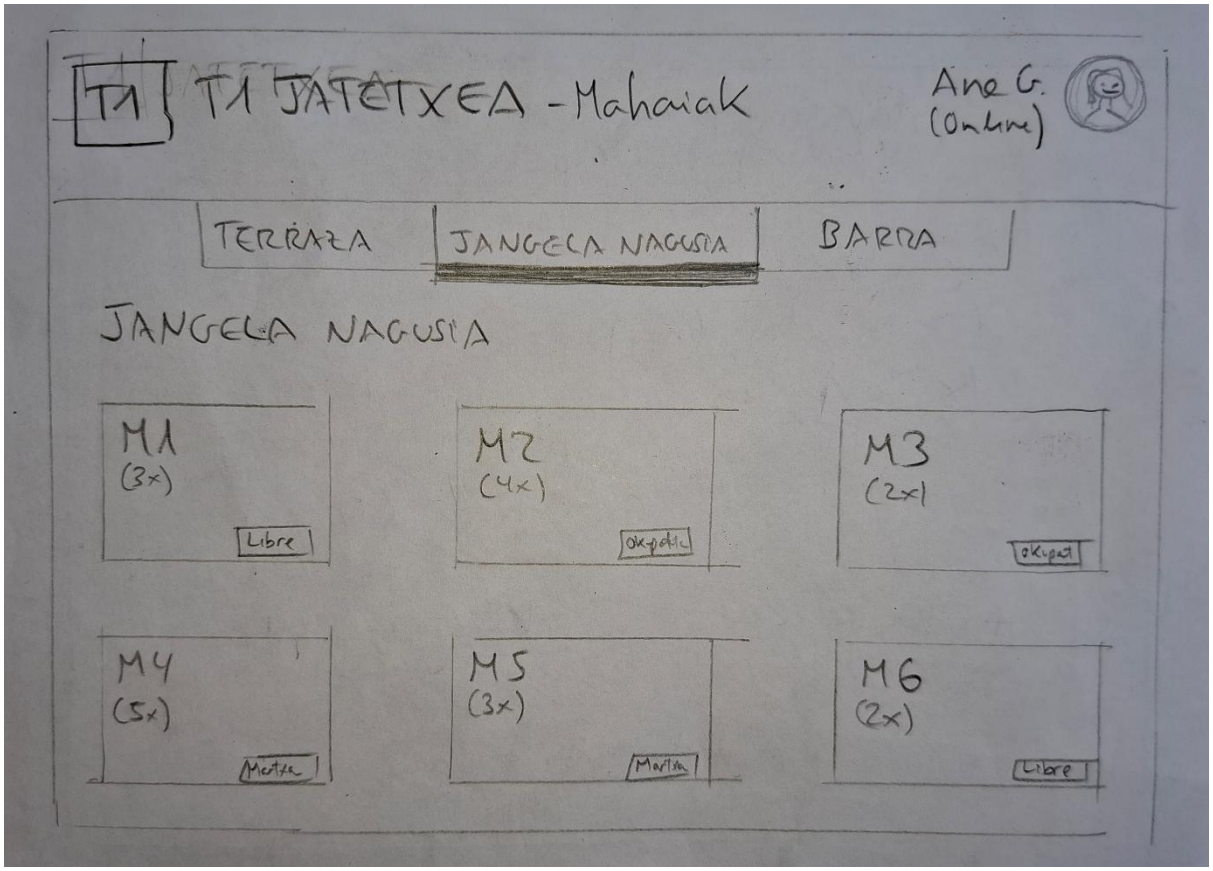


1.1. Irudia: Saioa Hasi pantailaren eskuzko zirriborroa (arkatzez)

- **Ezaugarriak:** Zerbitzarien argazki-zerrenda, 0-9 ukipen-teklatu zenbakizkoa, 'HASI SAIOA' botoia eta errore-eremua.

1.2 Pantaila: Mahaien Zerrenda eta Mapa

Jatetxeko aretoen ikuspegi globala (Jangela Nagusia, Terraza, Barra), mahaien egoera kolore bidez kontrolatzeko.

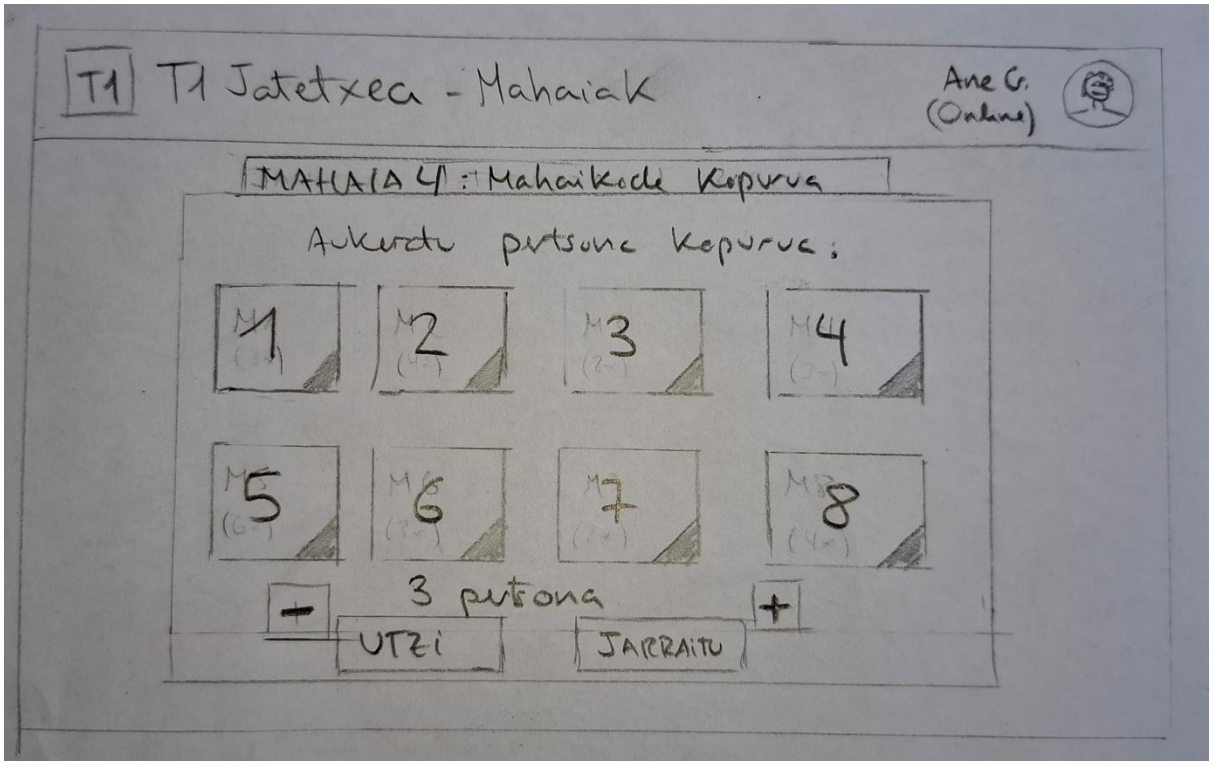


2.1. Irudia: Mahaien zerrendaren eskuzko zirriborroa (arkatzez)

- **Ezaugarriak:** Kolore-kode argia (Berdea = Librea, Gorria = Okupatua, Horia = Sukaldean) eta edukiera ofiziala.

1.3 Pantaila: Mahaikide Kopuruaren Hautatzailea (Modala / Pop-up)

Mahai librea hautatzean, leiho modal azkar bat irekitzen da mahaian zenbat pertsona eseri diren finkatzeko.

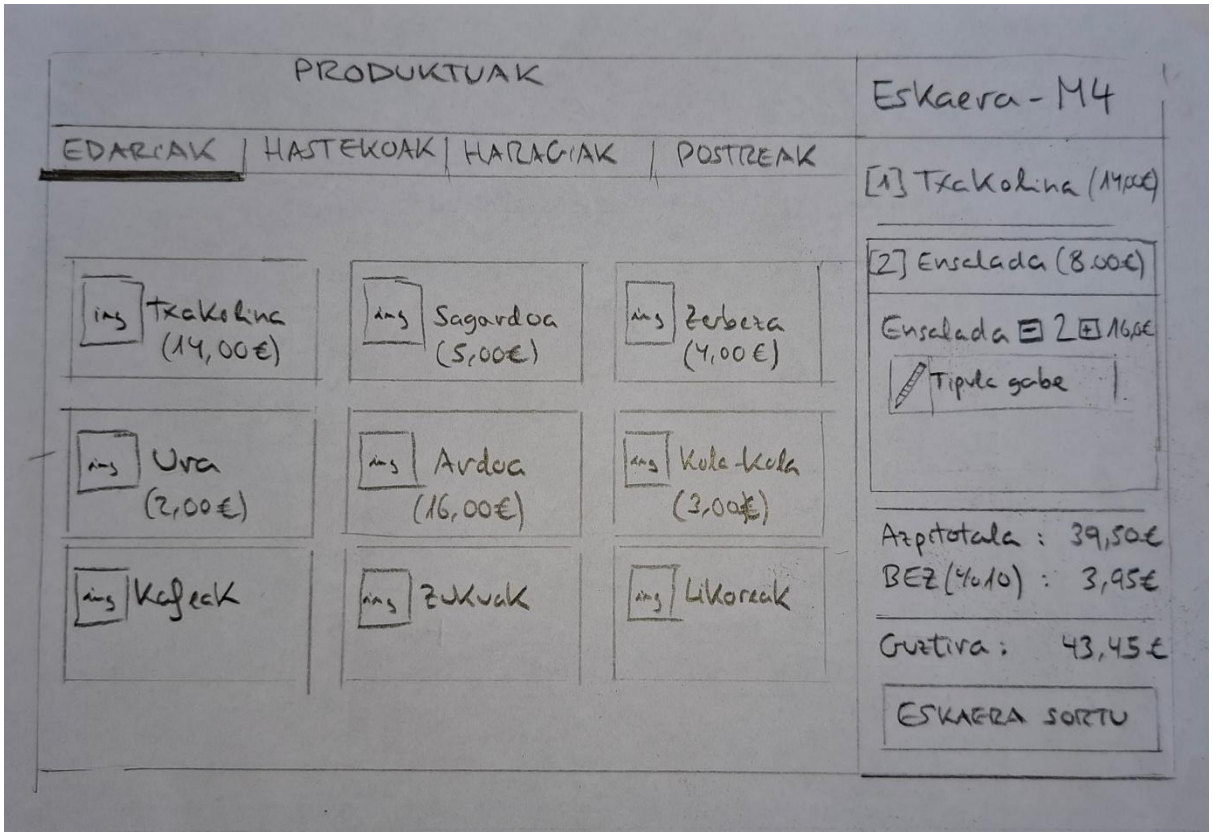


3.1. Irudia: Mahaikide kopurua hautatzeko modalaren eskuzko zirriborroa (arkatzez)

- **Ezaugarriak:** Zenbaki-botoi azkarrak (1-8+), '+' eta '-' botoiak, aforo maximoaren abisua eta 'Jarraitu' botoia.

1.4 Pantaila: Produktuak eta Karritoa (Komanda Sortzea)

Ezkerrean plateren katalogoa kategoriaka eta eskuinean uneko eskaeraren karrito interaktiboa.

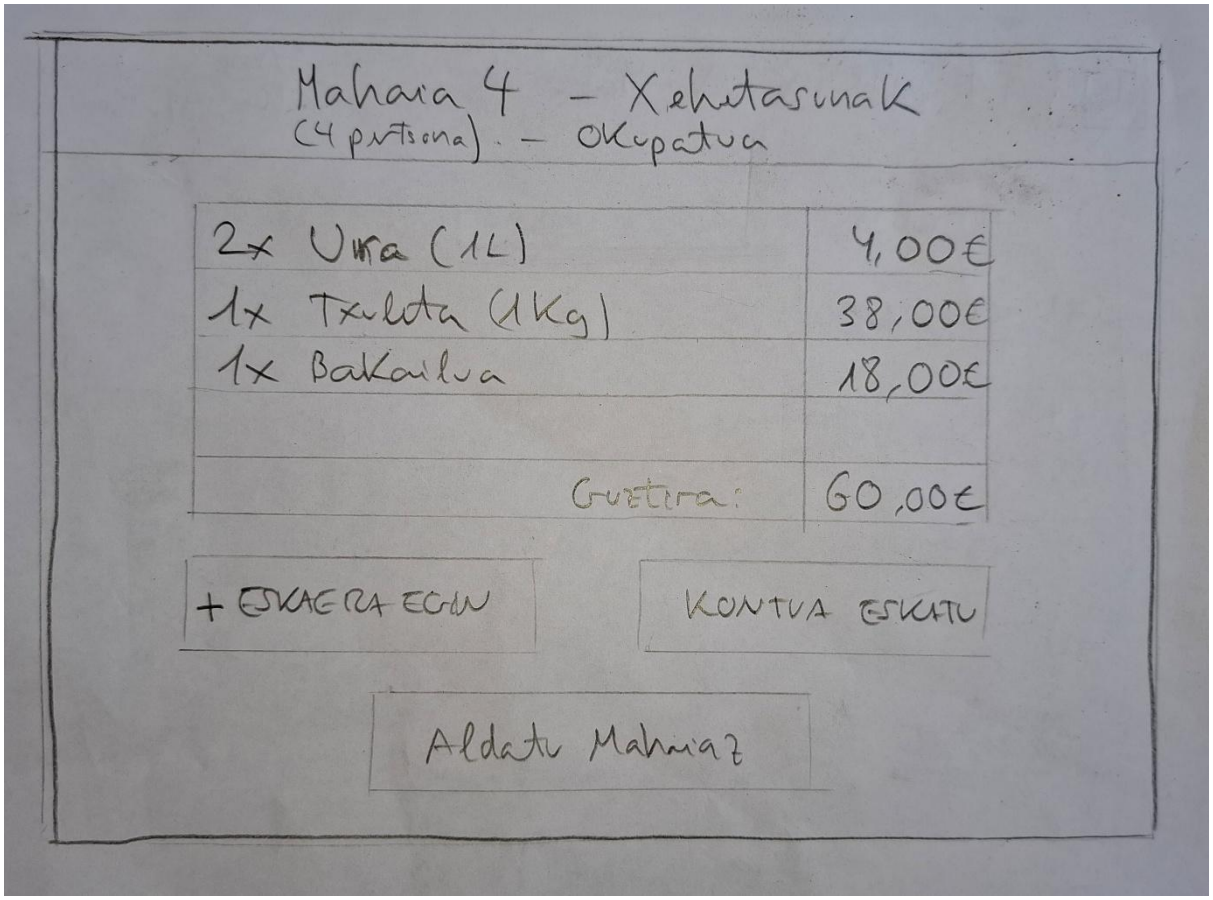


5.1. Irudia: Produktuen eta karritoaren eskuzko zirriborroa

- **Ezaugarriak:** Kategoria-fitxak, plateren txartelak argazki eta prezioarekin, karritoan kantitate-aldatzailea, ohar pertsonalizatuak (adib. 'Puntuan', 'Glutenik gabe'), eta 'ESKAERA SORTU' ekintza-botoia.

1.5 Pantaila: X. Mahaiaren Pantaila (Mahaiaren Xehetasuna)

Mahaia hautatu eta mahaikide kopurua finkatutakoan irekitzen den kudeaketa-pantaila nagusia.



4.1. Irudia: Mahaiaren xehetasun-pantailaren eskuzko zirriborroa (arkatzez)

- **Ezaugarriak:** Mahaiaren egoera eta pertsona kopurua (adib. 'Mahaia 4 - 4 pertsona'), lehendik eskatutako platerak, guztirako batura eta '➕ ESKAERA GEHITU' botoi nagusia.
- **ESKARA EGIN BOTOIA** da botoi garrantzitsuena eskarea sortzen duelako eta sukaldera bidali.
- PRODUKTUAK botoi bat gehitu beharko litzateke PRODUKTUAK pantailara joateko eskaerako produktuak aukeratzea.
- Mahaieko bezero kopurua aldatzeko (jarri nahi bada) beste botoi bat goiburuan.

2.Front-ean zein balidazioak

2.1 Helburua

Frontend-eko balidazioen helburu nagusia **erabiltzailearen esperientzia (UX)** eta erosotasuna hobetzea da: zerbitzariari berehalako feedback bisuala ematea, akats arrunten aurrean gidatzea eta sarera alferrikako eskaera gaizki-formatuak ez bidaltzea.

> ⚠ **Garrantzitsua: Frontend-ak EZ du segurtasunik bermatzen!**
> **«Frontean egindako balidazioa erosotasunerako da, ez segurtasunerako».** Edozein erasotzailek arakatzailearen DevTools erabiliz edo Postman/cURL bidez bezeroaren aldeko murrizketa guztiak oso erraz gaindi ditzake. Beraz, segurtasuna ezin da inoiz frontend-ean bakarrik utzi.

2.2Frontend Balidazioak

A. Saioa Hasi (Login Pantaila):

- **Eremu hutsak saihestea:** Zerbitzaria hautatu gabe badago edo PINa hutsik badago, 'HASI SAIOA' botoia ezgaituta (disabled) egongo da.
- **Formatua eta karaktereak:** Ukipen-teklatuak digitu zenbakizkoak soilik onartzen ditu; letrak edo ikurrak sartzea fisikoki blokeatuta dago.
- **Luzera finkoa:** PINak 4 eta 6 zenbaki artean izan behar ditu; motzegia bada abisu gorria erakusten da.
- **Klik anitzeko babesa (Double-Submit):** Botoia sakatu bezain laster 'Kargatzen...' egoeran jarri eta desgaitu egiten da eskaera bikoiztuak ez bidaltzeko.

B. Mahaien Zerrenda eta Mahaikide Modala (Pop-up):

- **Mahaiaren egoera:** Mahaia 'Garbitzeke' edo 'Itxita' badago, klik egitea ezgaituta egongo da.
- **Mahaikide kopurua (> 0):** Gutxienez pertsona 1 hautatu behar da; ezin da 0 edo balio negatiborik ezarri. 'Jarraitu' botoia blokeatuta egongo da 0 bada.
- **Zenbaki osoak (Integer):** Botoiek zenbaki osoak soilik aukeratzen uzten dute (ez hamartarrik, ez testurik).
- **Aforo maximoaren kontrola:** Mahaiaren edukiera ofiziala baino pertsona gehiago hautatuz gero (adib. 4 laguneko mahaian 6), abisu bisual horia agertzen da pantailan.

C. Produktuen Katalogoa eta Karritoa (Komanda):

- **Karrito hutsa eragoztea:** 'ESKAERA SORTU' botoia desgaituta mantentzen da karritoan gutxienez produktu 1 gehitu arte.
- **Kantitate minimoak:** Plateren unitateak beti >= 1 izan behar dira. Kantitatea 1 denean '-' sakatuz gero, produktua karritotik kentzen da.
- **Oharren luzera:** Sukalderako oharren testu-eremuan gehienez 150 karaktere onartzen dira, karaktere-kontagailu bisualarekin.
- **Stockaren tokiko feedbacka:** Plater baten stocka 0 bada, txartela grisatu eta '+' botoia desgaitzen da 'Agortuta' etiketa jarriz.

3. Back-ean balidazioak

3.1 Egingo diren Balidazio Nagusiak eta Nola

- **Kredentzialak:** Zerbitzariaren PINa bcrypt bidez egiaztatuko da segurtasuna bermatzeko.
- **Prezioen Kontrola:**Frontend-etik datorren prezio bakar bat ere EZ DA ONARTZEN. Produktuen prezio ofizialak beti backend-eko datu-basetik irakurriko dira, iruzurrak saihesteko.
- **Aforo eta Kapazitate Kontrola:** Datu-basean egiaztatuko da pertsona_kopurua <= mahaiak.kapazitate_maximoa dela.
- **SQL Injection Prebentzioa:** Datu guztiak kontsulta parametrizatuen bidez (Prepared Statements) kudeatuko dira; parametroak datu gisa tratatuko dira, ez kode gisa.
- **Segurtasuna Datu Base Mailan:** Datu-basean bertan babes-hesiak ezarriko dira: CHECK (stock >= 0), FOREIGN KEY, NOT NULL eta UNIQUE mugak.

Jatetxeko Datu-Eremua / Ekintza	Zein balidazio egingo da?	Nola aplikatuko da Backend-ean?	Jatetxeko Kasu Erreala eta Arriskua
Zerbitzariaren PINa (Identifikazioa / Login)	Formatua zenbakizkoa (4-6 digitu) izatea eta kode zifratu seguruarekin (hash) bat etortzea.	Regex bidez formatua baieztatu (`^\d{4,6}$`) eta datu-baseko hash-arekin konparatu (`BCrypt.Verify`). Inoiz ez testu arruntean.	Zerbitzari oker batek beste baten izenean komandak bidaltzea edo zerbitzariaren sarbidea manipulatzea.
Mahaiaren Egoera eta IDa	Mahaia existitzen dela eta une horretan erabilgarri (libre) dagoela egiaztatzea.	Datu-basetik mahaiaren uneko egoera kontsultatu (`SELECT egoera FROM mahaiak WHERE id = @id`).	Lehendik bezeroekin okupatuta dagoen edo garbitzen ari diren mahai batean eskaera berria gainidaztea.
Mahaikide Kopurua	Zenbaki oso positiboa izatea (≥ 1) eta mahaiaren gehieneko edukiera ez gainditzea.	`1 <= pertsonak <= mahaiak.kapazitate_maximoa` dela egiaztatu backend-eko negozio-logikan.	4 laguneko mahai batean 12 pertsona sartzea (aretoaren aforoa desitxuratuz) edo akatsez 0 edo zenbaki negatiboak bidaltzea.
Plateren Prezioak	Prezioak datu-basetik bakarrik kalkulatzea; tabletak bidalitako preziorik ez onartzea.	Tabletatik soilik plateraren IDa (`id_produktua`) onartu, eta prezio ofiziala zuzenean datu-basetik eskuratu kontua kalkulatzeko.	Zerbitzari batek edo bezero batek 45 €-ko txuletoiaren prezioa aldatu eta 0,50 €-tan kobratzea.
Plateren Kantitatea	Kantitatea zenbaki oso positiboa izatea (≥ 1).	Sarrerako datuen ereduan baliozkotu (`kantitatea >= 1`).	Eskaera batean 0 unitate edo kantitate negatiboak sartzea, fakturaren baturak desorekatuz.
Osagaien / Plateren Stocka	Biltegian eskatutako plater edo edarirako nahikoa unitate daudela baieztatzea.	Stocka egiaztatu transakzioan (`stock >= eskatutakoa`); nahikoa ez bada, eskaera atzera bota.	Sukaldean geratzen den azken arrain-platera bi mahairi batera saltzea eta sukaldean prestatu ezin izatea.
Sukalderako Oharrak	Karaktere-mota mugatzea (letrak, zenbakiak, puntuazio arrunta) eta luzera mugatzea (≤ 150 kar.).	Baimendutako karaktereen zerrenda aplikatu (Whitelist Regex) eta kontsulta parametrizatuak erabili.	Sukaldeko monitorean karaktere bereziek errorea eragitea edo oharrean komatxoak erabiliz SQL injekzioa egitea.

Jatetxeko datuak seguru kudeatzeko, backend-ak hiru urrats errazetan aplikatzen ditu balidazio hauek:

Sarrerako Datuen Formatu-Iragazkia:

- Tabletetik datuak iritsi bezain pronto, eremu bakoitzak beharrezko egitura betetzen duela egiaztatzen da.
- *Kasu erreala:* Zerbitzariak PINa sartzean 4-6 digitu zenbakizko direla ziurtatzen da; pertsona kopuruan zenbaki positiboak soilik onartzen dira (ezin da 0 edo negatiborik bidali); eta sukalderako oharretan gehienez 150 karaktere baimentzen dira. Daturen bat gaizki badator, backend-ak berehala atzera botatzen du eskaera

Datu-Basearen Aurkako Negozio-Egiaztapenak:

- Datuak ez dira tabletak dioenaren arabera onartzen; backend-ak bere datu-basea kontsultatzen du:
  - **Prezio ofizialak:** Tabletak bidalitako prezio guztiak baztertu eta backend-ak bere katalogoko prezio erreala ezartzen du.
  - **Mahaiaren aforoa:** Egiaztatzen du mahaia libre dagoela eta eseri diren pertsonak mahaiaren tamainarekin bateragarriak direla.
  - **Stock erreala:** Plater bakoitzaren eskuragarritasuna egiaztatzen du sukaldean unitaterik gabe ez geratzeko.

Kontsulta Parametrizatuak (SQL Injekzioaren Aurkako Babesa):

- Sukalderako oharrak ("Puntuan, gatza gutxi") edo zerbitzariaren datuak gordetzean, SQL aginduak parametro bidez bidaltzen dira beti (`@oharra` , `@id_mahaia`). Horrela, testuan komatxoak edo karaktere bereziak egon arren, datu-baseak testu soil bezala tratatzen ditu, inoiz ez agindu exekutagarri gisa.

4. Transakziok eta nola aplikatu

4.1 Arazo posibleak eta nola saihestu transakzioekin

Transakzioak ahalbidetzen digute eragiketak multzoka egitea horrela saihestuz eragiketaren bat gaizki joaten baldin bada ez gelditea erdizka egina, dena egiten da edo ez da ezer egiten.

Gure kasuan egon daizken arazo posibleak:

1. **Momentu berean zerbitzari bat baino gehiago mahai bat aukeratzea.**
2. **Eragiketa batzuk egiterakoan atalen bat errorea ematea eta prozesua horrela erdizka egitea(ordaintzerakoan alde batetik dirua kentzea eta besteari ez gehitzea).**
3. **Platerrak eskatzerakoan ez edukitzea osagai kopuru nahikoa.**

Egoera hauek ez gertatzeko edo konpontzeko transakzioak egingo dira:
Transakzio guztietan if baldintzak eta saiakerak erabiliko dira.

1. **Hemen konpontzeko pertsona bat baino gehiago leku berean sartzea erabiliko genuen transakzioan Select for update, bik egingo zuten hori eta blokeo batean sartuko ziren eta transakzioak bat kanpora botako zuen eta besteak transakzioa egingo zuen, horrela saiakerak erabilita beste ondoren sartzen da eta ikusten du ezin duela egin eta mezu bat agertzen zaio.**

2. **Hemen transakzio simple batekin funtzionatuko zuen baino baita sartuko genuen saiakera kopuru batzuk egin ahal izatea eta if baldintza batzuk konprobatzeko eragiketa egin baino lehenago kontuan ordaindu behar duena baino diru gehiago duela.**

3. **Kasu honetan sahiesteko dauden plater kopurua baino gehiago aukeratzea 2 transakzio erabiliko genituen, 1 izango zen select for share erabiliz, horrela bestea ikusi dezake platerra baino egoera ezin du aldatu guk platerra aukeratu harte, bestea izango zen platerraren kantitatea zehazterakoan, gure sistema aukera egongo da kantitatea igotzea eta jeistea banan banan orduan hori egiterakoan transakzio bat irekiko da produktua for share bat eginez eta baldintzekin konprobatuz kendu edo igo dezakegun.**

Jatetxeko Egoera Erreala	Arriskua Transakziorik Gabe	Nola aplikatu behar da Transakzioa?	Emaitza Datu-Basean
Eskaera osatua sukaldera bidaltzea	Konexioa eteten bada erdian: eskaera sortuta geratuko litzateke baina platerak gorde gabe, edo stocka kendu baina eskaera ez gorde.	Transakzio bakarrean biltzen dira: eskaera sortu + lerroak txertatu + stocka kendu + mahaia okupatu.	Eragiketa guztiak ondo badoaz **COMMIT** egiten da; arazorik balego **ROLLBACK** (dena hasierako egoera garbian geratzen da).
Azken platera bi zerbitzarik batera eskatzea (Adib. txuleta bakarra geratzen denean)	Bi zerbitzariek stock = 1 ikusi eta biek saltzen dute. Biek `stock = 0` idazten dute, baina 2 txuleta saldu dira eta sukaldean bakarra dago.	Platera kontsultatu eta stocka deskontatzean errenkada blokeatu egiten da (`UPDATE produktuak SET stock = stock - 1 WHERE id = @id AND stock >= 1`).	Lehen zerbitzariak platera saltzen du; bigarrenari jakinarazten zaio stockik ez dagoela eta bere eskaera atzera botatzen da.
Mahai bera bi zerbitzarik batera irekitzea	Zerbitzari batek 3. mahaia irekitzen du eta segundo berean beste batek mahai bera hartzen du beste bezero batzuentzat.	Transakzio hasieran mahaiaren egoera kontsultatu eta blokeatu egiten da.	Lehenengo zerbitzariak 'okupatua' egoeran jartzen du; bigarrenari errore-mezua agertzen zaio mahaia jada hartuta dagoela esanez.
Plater baten stock falta komanda erdian (Adib. 4 plateretik 1 agortuta dago)	Aurreko 3 plateren stocka deskontatuta geratuko litzateke, nahiz eta eskaera osoa ezin den zerbitzatu.	Datu-baseak errorea sortzen du stock negatiboa saihesteko (`CHECK stock >= 0`), eta transakzio osoa atzera botatzen da.	Aurretik deskontatutako platerak berehala itzultzen dira biltegira; ez da eskaera erdirik sortzen.
Tabletak kobertura galtzea eskaera bidaltzean	Datuak erdizka gordeta geratzea datu-basean.	Backend-eko `try...catch` egiturak sareko errorea harrapatu eta automatikoki `ROLLBACK` agindua exekutatzen du.	Datu-basea garbi mantentzen da eta zerbitzariari tabletean eskatzen zaio berriro saiatzeko.

Jatetxeko aplikazioan transakzioak modu arin eta seguruan funtzionatzeko, lau arau erraz hauek jarraitu behar dira:

1. **Noiz ireki eta noiz itxi transakzioa (Transakzio Laburrak):**
   - **EZ EGIN:** Zerbitzariak bezeroekin hitz egin eta tabletean platerak aukeratzen dituen bitartean (2-3 minutu) transakzioa irekita edukitzea. Hori eginez gero, datu-baseko taulak blokeatuta geratuko lirateke eta beste zerbitzariek ezingo lukete beste mahaietan lanik egin.
   - **EGIN:** Transakzioa zerbitzariak **"ESKAERA SORTU"** botoia sakatzen duen unean bertan irekitzen da backend-ean. Milisegundo gutxitan datuak gorde, egiaztatu eta berehala ixten da (`COMMIT`).
2. **Stock-deskontu segurua (Gatazkak saihesteko):**
   - Plateren kantitatea jaisteko unean, egiaztapen zuzena egiten da: unitateak deskontatu soilik uneko stocka eskatutako kantitatea baino handiagoa edo berdina bada. Unitaterik ez badago, eragiketak huts egiten du eta eskaera osoa atzera botatzen da.
3. **Akatsen kudeaketa eta Rollback automatikoa:**
   - Backend-eko kodean eragiketa guztiak babes-bloke batean sartzen dira (`try / catch`). Urrats bakar batean akatsen bat gertatzen bada (sare-mozketa, datu-basearen gatazka edo stock eza), kodeak automatikoki `ROLLBACK` exekutatzen du eta aldaketa guztiak desegiten dira.
4. **Datu-base motorea (InnoDB):**
   - Datu-baseko taula guztiek transakzioak onartzen dituen motorea erabili behar dute derrigorrez (MySQL-n **InnoDB** erabili behar da; MyISAM motoreak ez ditu transakzioak onartzen eta ezin du Rollback-ik egin).